Inhalt

Handshake knacken mit Kali Linux 2
Ausgangslage 2
Die drei Werkzeuge und Angriffsmodelle 2
Offline-Angriff auf den eigenen Handshake mit hashcat 2
Wörterbuchangriff mit rockyou 3
Ergebnis des Wörterbuchangriffs 3
Brute-Force-Angriff mit Teilwissen 4
Werkzeug-Demonstration John the Ripper 4
Werkzeug-Demonstration Hydra (Online-Angriff) 5
Technische Erkenntnisse 6
Fazit 6

Handshake knacken mit Kali Linux

Praxisübung im eigenen WLAN, Auswertung der gefangenen WPA-Handshakes

Bearbeiter	Jakob (Tscheky)
Umgebung	Zuahuse, eigenes Testnetz
System	Kali Linux (Hyper-V VM), hashcat, John the Ripper, Hydra
Ziel	Eigener WPA-Handshake vom Evil-WPA-Twin Magenta_cb0501_fef568
Datum	21.10.2026

Ausgangslage

In der vorherigen Übung wurden über einen Evil-WPA-Twin mehrere WPA-Handshakes des eigenen Netzes gefangen. Diese Übung befasst sich mit der Auswertung, also dem Versuch, aus einem Handshake das Passwort offline zu ermitteln. Dafür wurde eine Kali-Linux-Umgebung eingerichtet und mit drei Standardwerkzeugen gearbeitet.

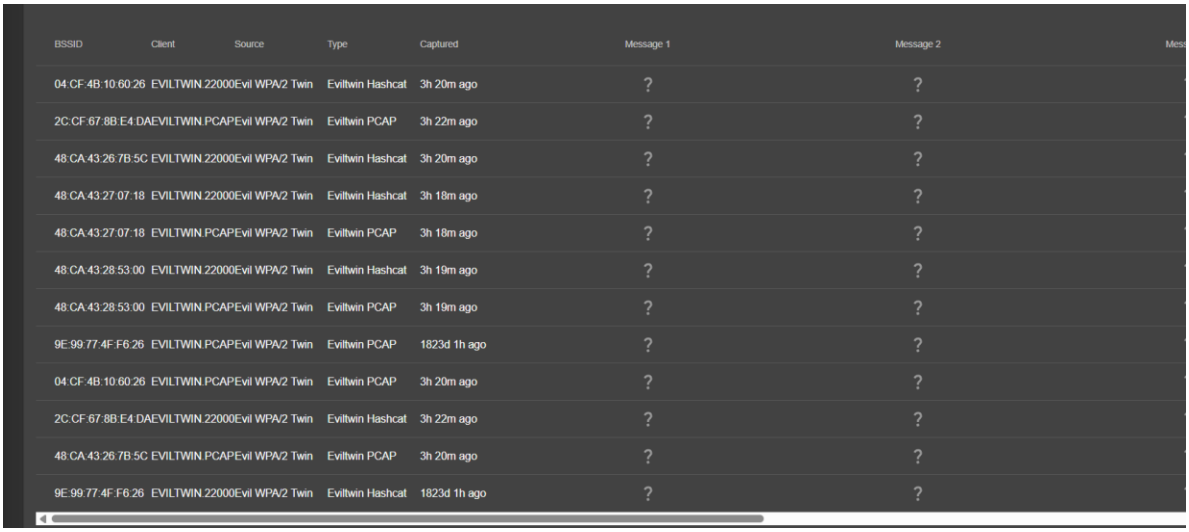
Die drei Werkzeuge und Angriffsmodelle

hashcat und John the Ripper arbeiten offline, also gegen eine gefangene Datei oder einen Hash. Hydra arbeitet online, also live gegen einen laufenden Dienst wie SSH. Diese Unterscheidung ist zentral: ein WPA-Handshake wird offline geknackt, ein Login-Dienst online angegriffen.

Offline-Angriff auf den eigenen Handshake mit hashcat

Handshake auswählen und auf Kali bringen

Im Pineapple liegen die gefangenen Handshakes unter Evil WPA. Jeder Eintrag gehört zum Twin Magenta_cb0501_fef568 (BSSID 00:13:37:BE:EF:00). Das Hashcat-Format (Endung 22000) wurde heruntergeladen und per Dateimanager in das Kali-System übertragen.



BSSID	Client	Source	Type	Captured	Message 1	Message 2
04:CF:4B:10:60:26	EVILTWIN	22000	Evil WPA/2 Twin	Eviltwin Hashcat	3h 20m ago	?	?
2C:CF:67:8B:E4:DA	EVILTWIN	PCAP	Evil WPA/2 Twin	Eviltwin PCAP	3h 22m ago	?	?
48:CA:43:26:7B:5C	EVILTWIN	22000	Evil WPA/2 Twin	Eviltwin Hashcat	3h 20m ago	?	?
48:CA:43:27:07:18	EVILTWIN	22000	Evil WPA/2 Twin	Eviltwin Hashcat	3h 18m ago	?	?
48:CA:43:27:07:18	EVILTWIN	PCAP	Evil WPA/2 Twin	Eviltwin PCAP	3h 18m ago	?	?
48:CA:43:28:53:00	EVILTWIN	22000	Evil WPA/2 Twin	Eviltwin Hashcat	3h 19m ago	?	?
48:CA:43:28:53:00	EVILTWIN	PCAP	Evil WPA/2 Twin	Eviltwin PCAP	3h 19m ago	?	?
9E:99:77:4F:F6:26	EVILTWIN	PCAP	Evil WPA/2 Twin	Eviltwin PCAP	1823d 1h ago	?	?
04:CF:4B:10:60:26	EVILTWIN	PCAP	Evil WPA/2 Twin	Eviltwin PCAP	3h 20m ago	?	?
2C:CF:67:8B:E4:DA	EVILTWIN	22000	Evil WPA/2 Twin	Eviltwin Hashcat	3h 22m ago	?	?
48:CA:43:26:7B:5C	EVILTWIN	PCAP	Evil WPA/2 Twin	Eviltwin PCAP	3h 20m ago	?	?
9E:99:77:4F:F6:26	EVILTWIN	22000	Evil WPA/2 Twin	Eviltwin Hashcat	1823d 1h ago	?	?

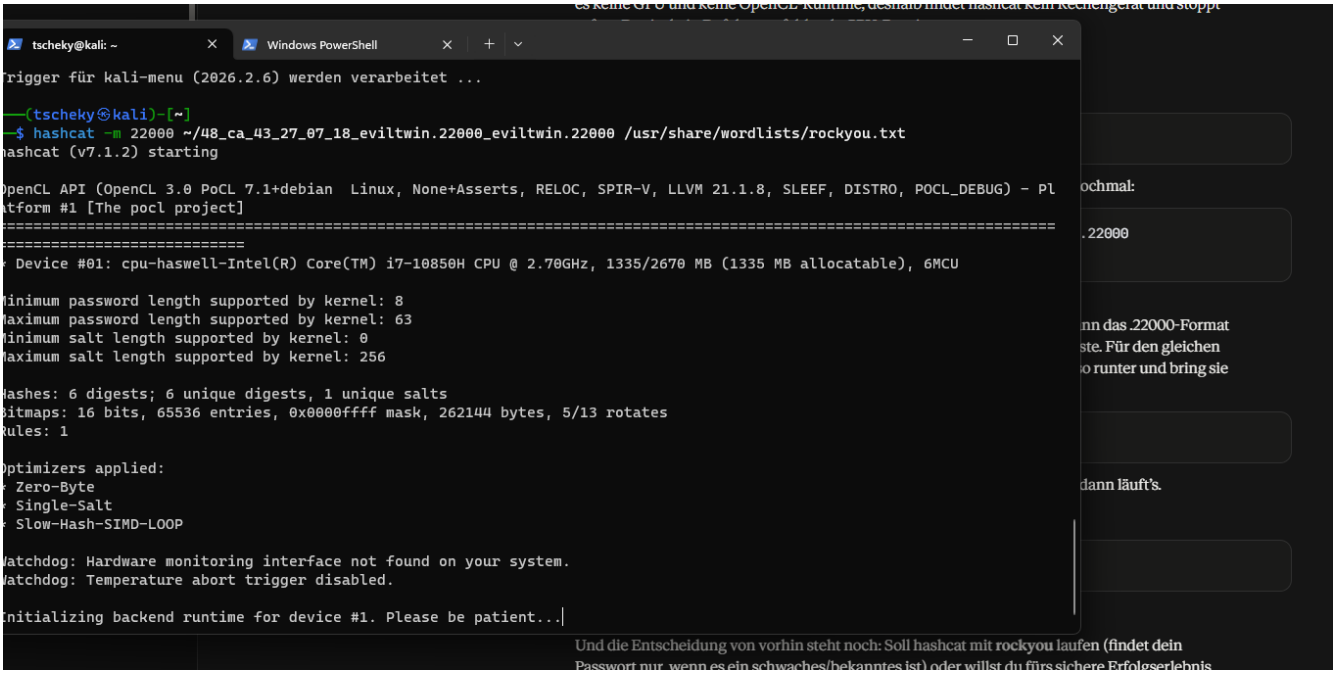


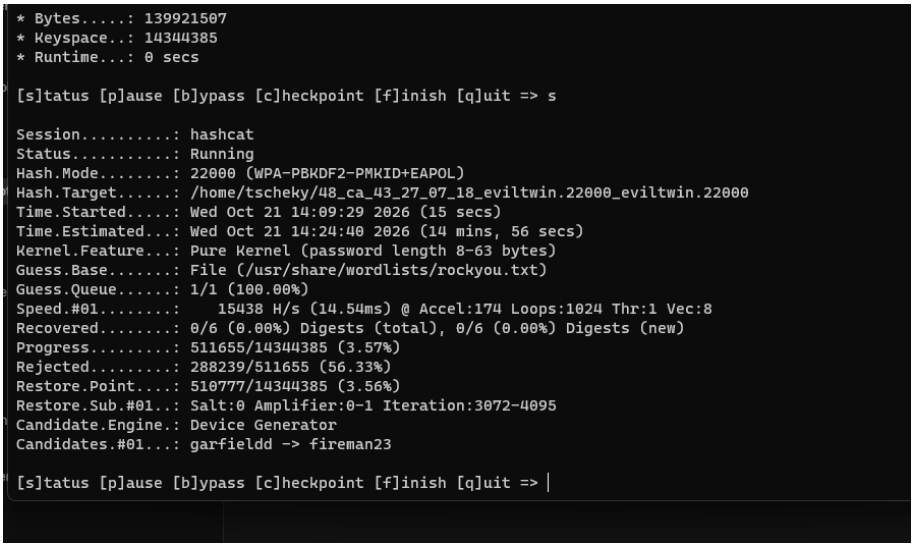
```
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.31.126' (ED25519) to the list of known hosts.
tscheky@192.168.31.126's password:
ssh: Could not resolve hostname c: No address associated with hostname
scp: Connection closed

┌──(tscheky㉿kali)-[~]
└─$ ls -lh ~/48_ca*
-rw-r--r-- 1 tscheky tscheky 2,5K 21. Okt 14:05 /home/tscheky/48_ca_43_27_07_18_eviltwin.22000_eviltwin.22000
```

Wörterbuchangriff mit rockyou

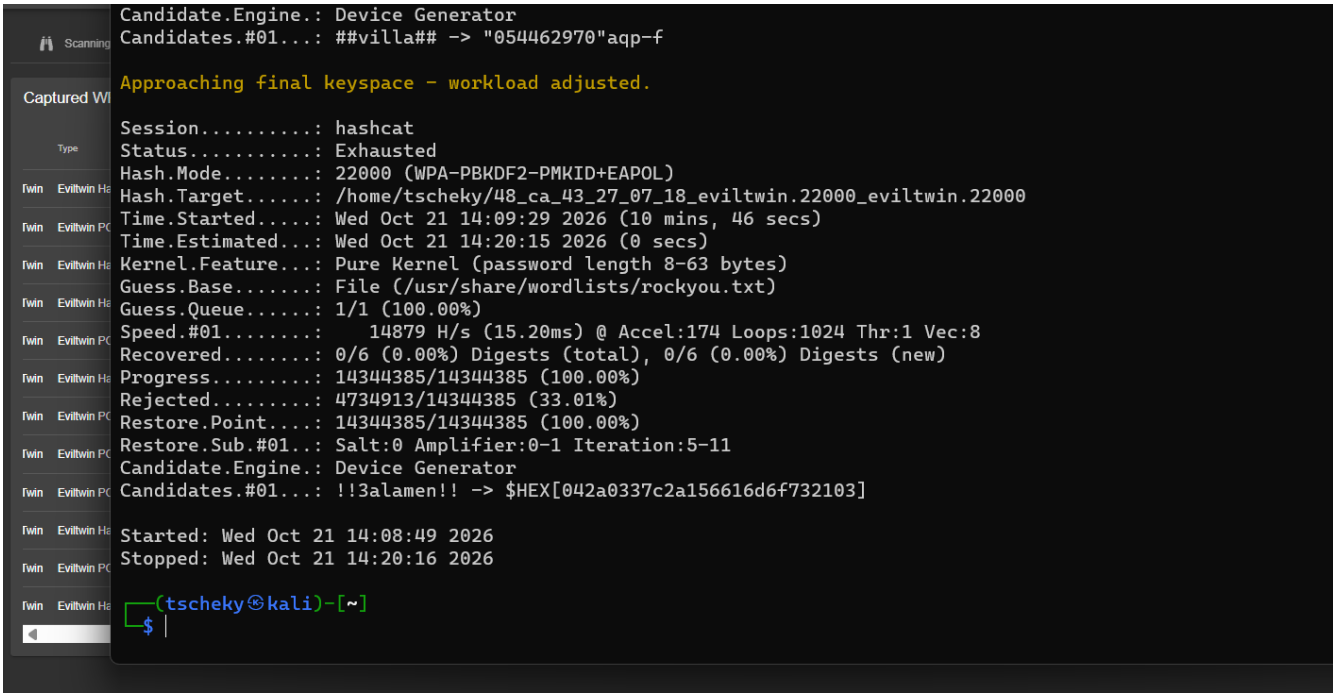
In der VM gibt es keine Grafikkarte, daher musste für hashcat die CPU-Laufzeit pocl nachinstalliert werden. Danach lief hashcat im Modus 22000 gegen die bekannte Wörterbuchliste rockyou mit rund 14 Millionen Passwörtern. Die Datei enthielt sechs Handshakes, die gleichzeitig geprüft wurden.





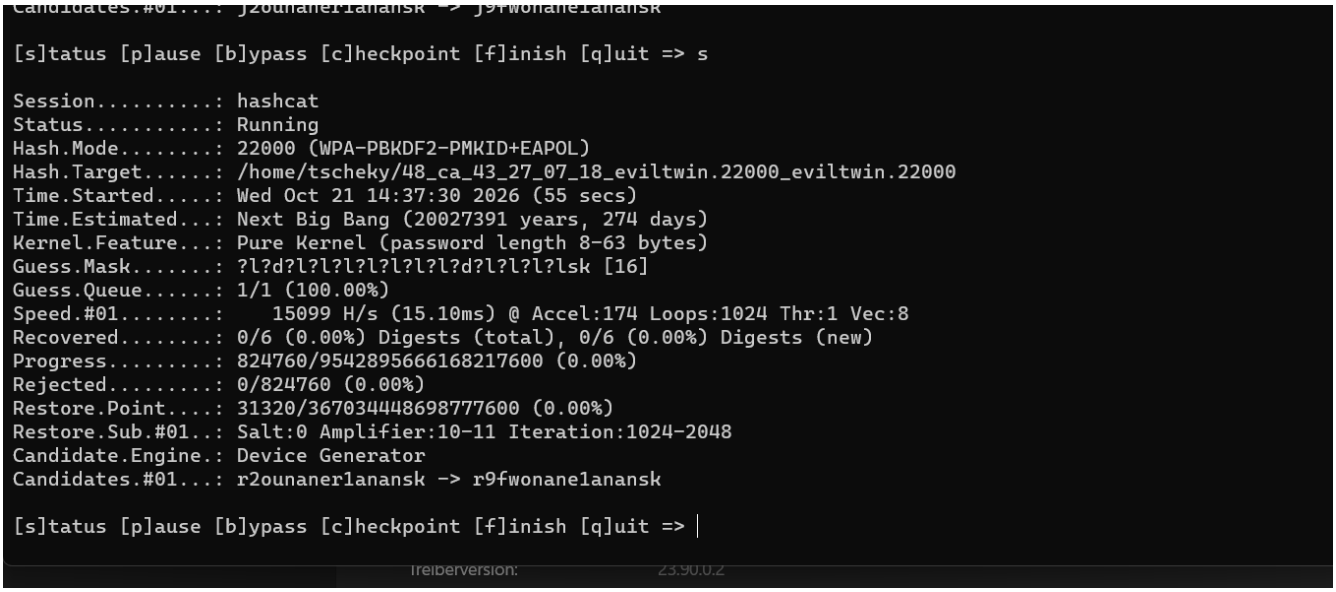
Ergebnis des Wörterbuchangriffs

Nach dem vollständigen Durchlauf meldete hashcat Status Exhausted und Recovered 0 von 6. Keiner der eigenen Handshakes wurde geknackt. Das bedeutet: Das Passwort steht in keiner der geleakten Listen. Das ist ein gutes Ergebnis, denn genau das soll ein sicheres Passwort leisten.



Brute-Force-Angriff mit Teilwissen

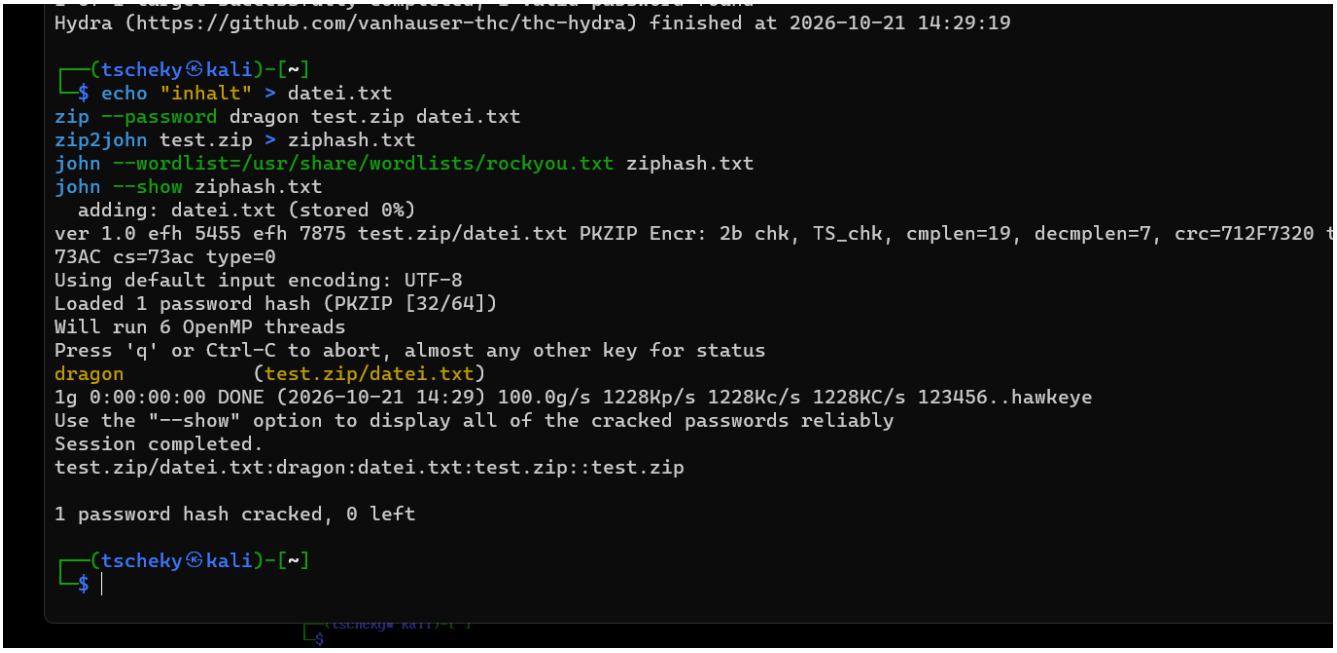
Als zweiter Versuch wurde ein Brute-Force-Angriff mit einer Maske gestartet. Das Passwort ist 16 Zeichen lang und besteht aus Kleinbuchstaben und Ziffern. Selbst mit Kenntnis mehrerer Zeichenpositionen bleiben zu viele Kombinationen übrig. hashcat schätzte die Laufzeit auf über 20 Millionen Jahre (Anzeige Next Big Bang) bei einem Suchraum von etwa 9,5 Trillionen Möglichkeiten. Der Angriff ist damit praktisch nicht durchführbar.



Werkzeug-Demonstration John the Ripper

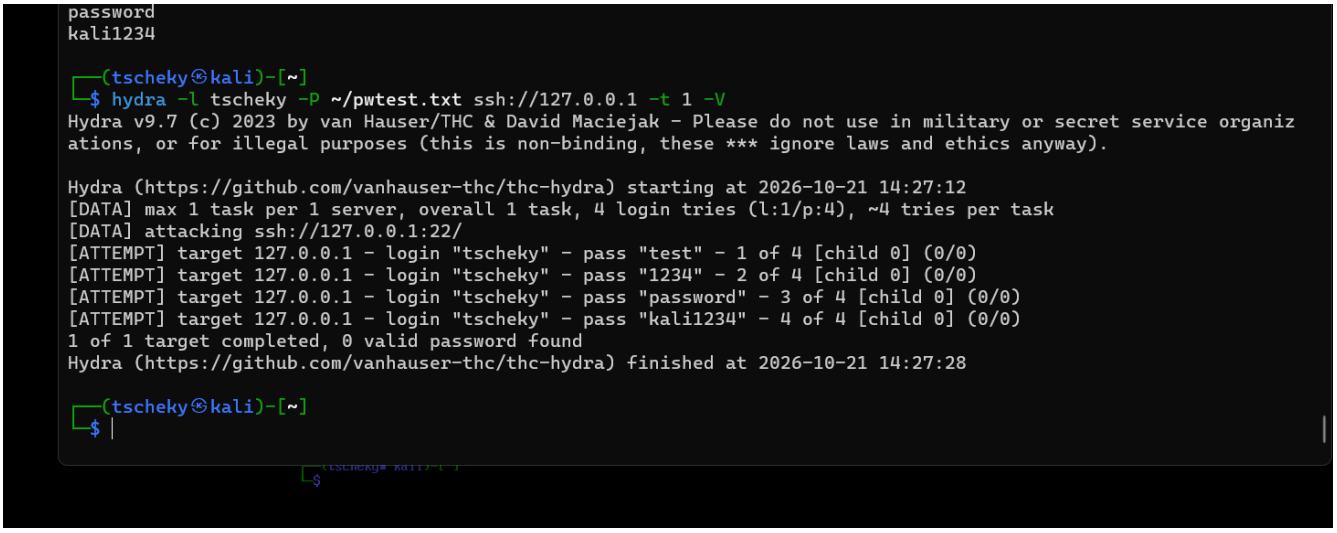
John the Ripper kann denselben Offline-Angriff. Das 22000-Format des WLAN-Handshakes ließ sich mit der Kali-Standardversion jedoch nicht einlesen, daher wurde John an einem anderen Ziel gezeigt: einer passwortgeschützten ZIP-Datei. Mit dem Hilfsprogramm zip2john wurde der Passworthash extrahiert und mit rockyou geknackt. Das schwache Passwort wurde in unter einer Sekunde gefunden.

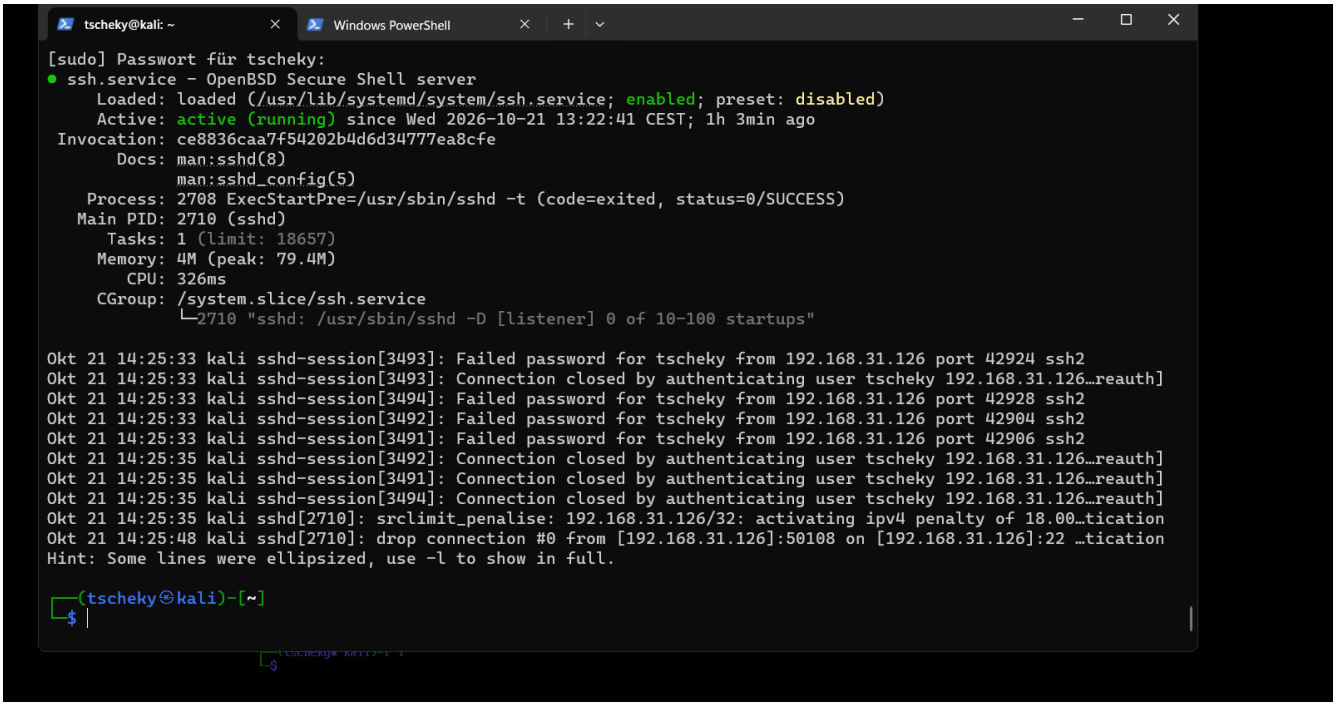
Das zeigt, wie schnell schwache Passwörter fallen, sagt aber nichts über das starke WLAN-Passwort aus.



Werkzeug-Demonstration Hydra (Online-Angriff)

Hydra verfolgt ein ganz anderes Angriffsmodell und wurde gegen den eigenen SSH-Dienst des Kali-Systems getestet. Hydra verbindet sich wiederholt und probiert Passwörter live aus. Interessant war die Reaktion des Servers: Nach wenigen schnellen Fehlversuchen aktivierte OpenSSH eine Strafsperre (srclimit penalise) und brach die Verbindung ab. Das ist eine eingebaute Schutzfunktion gegen Brute-Force.





Technische Erkenntnisse

Angriff	Ergebnis
hashcat Wörterbuch (rockyou)	Exhausted, 0 von 6, eigenes Passwort nicht in Leak-Listen
hashcat Brute-Force (16 Zeichen)	Praktisch unmöglich, Schätzung über 20 Millionen Jahre
John the Ripper (ZIP-Demo)	Schwaches Passwort in unter einer Sekunde geknackt
Hydra (SSH-Demo)	Server-Strafsperre greift gegen Brute-Force
Eigener WLAN-Handshake	Nicht geknackt, 16-stelliges Passwort zu stark

Fazit

Die Auswertung zeigt das Kernergebnis der gesamten Übung: Handshakes lassen sich fangen, sogar trotz Management Frame Protection über einen Evil Twin, aber das Knacken scheitert an einem starken Passwort. Der eigene WLAN-Handshake wurde mit keinem der Werkzeuge geknackt. Der Wörterbuchangriff lief ins Leere, der Brute-Force-Angriff ist mit über 20 Millionen Jahren Rechenzeit praktisch unmöglich. Treffer gab es nur an absichtlich schwachen Testzielen. Die Lehre ist eindeutig: Ein langes, gemischtes Passwort macht WPA2 praktisch unknackbar. Zusätzlichen Schutz bieten Rate-Limiting bei Diensten, SSH-Schlüssel statt Passwörter und die Vermeidung von Wörtern aus bekannten Leak-Listen.

Rechtlicher Hinweis. Alle Angriffe richteten sich ausschließlich gegen das eigene WLAN, den eigenen SSH-Dienst und selbst erstellte Testdateien. Das Knacken fremder Handshakes oder Passwörter ist in Österreich strafbar und nur mit ausdrücklicher Erlaubnis des Betreibers zulässig.